

Jasmin Fässler			01.06.2026
INFORMATION SECURITY (IS)			
Information: Data that has been processed in a way that gives it meaning and value			
Information security: Protection of the integrity, confidentiality and availability of information			
Non-repudiation: Prevents parties from denying their actions			
Accountability: Ability to trace actions back to a person			
Authentication: Verifies the identity of a user or system			
Authorization: Determines actions an entity is allowed to do			
Access control: Restrict access to resources based on rules			
Security policy: A rule/expectation for protecting information			
Compliance: Adherence to laws, regulations, and standards			
Types of information: Personal, business, financial, intellectual, system			
Components of an Information System (IS): Software, Hardware, Data, People, Procedures, Networks			
Bottom-Up: Implementations happen before policies			
Top-Down: Initiated by management, more effective			
McCumber cube: x: CIA (what), y: Information states (where), z: Control (how)			
(C)onfidentiality: Prevent unauthorized access to info			
(I)ntegrity: Protect reliability and correctness of information			
(A)vailability: Ensure uninterrupted access to information			
Information states: In storage, in transit, in use			
Control: A measure designed to reduce the potential risk of an attack by eg. Policy, Education, Technology			
(S)poofing: Pretending to be someone else			
(T)ampering: Unauthorized data modification or altering			
(R)epudiation: Denying actions without proof			
(I)nformation disclosure: Exposing sensitive information			
(D)enial of service: Making systems or services unavailable			
(E)levation of privilege: Gaining unauthorized rights			
THREAT CATEGORIZATION			
SOCIAL ENGINEERING			
Manipulating people to reveal confidential information			
Phishing: Forged emails impersonating legitimate entities			
Spear Phishing: Targeted phishing to specific individuals			
Vishing: Voice-based phishing over phone or video calls			
Smishing: SMS / Text-based phishing			
SOFTWARE ATTACKS			
Exploiting vulnerabilities in software to gain access to a system or steal data			
Virus: Malware that attaches to programs and spreads			
Worms: Self-replicating malware that spreads over a network			
Trojan Horse: Malicious sw disguised as legitimate apps			
Ransomware: Encrypts victim data, asks payment to restore			
Rootkits: Stealthy tools that hide malicious activity and maintain privileged access			
DENIAL OF SERVICE			
Overloading one or multiple systems to make it unavailable			
DoS: Single source denial of service attacks			
DDoS: DoS performed by multiple attackers/devices			
Botnet: Network of compromised devices controlled by an attacker and used to together to flood a target with traffic			
SYN-Flood Attack: Sending many TCP connection requests without completing them			
Reflection Attack: Attacker spoofs victim's IP, sends requests to a service so that it sends (many) replies to victim			
WEB APPLICATION ATTACKS			
Exploiting vulnerabilities in websites/servers hosting websites			
SQL Injection: Insert malicious SQL commands into an input			
Cross-Site Scripting (XSS): Inject malicious scripts into website that execute in users' browsers to steal data			
Cross-Site Request Forgery (CSRF): Trick logged-in user's browser into sending reqs to a webapp on attacker's behalf			
Broken Authentication: Weak auth mechanisms allow attackers to gain unauthorized access (password/session)			
PASSWORD / AUTHENTICATION ATTACKS			
Attempting to bypass or compromise login systems to gain unauthorized access			
Rainbow Table Attacks: Precomputed hash lookup tables to reverse weakly hashed passwords back into plaintext			
Password Spraying: Trying a few common passwords like "password" across many accounts to avoid lock-/timeouts			
Credential Stuffing: Using leaked credentials from previous breaches to attempt logins on other services			
Brute Force Attack: Repeatedly try many username & password combinations until they gain access to an account			
PHYSICAL ATTACKS			
Bypassing technical controls by accessing physical infrastructure directly			
Theft of devices: Physically steal hardware to gain direct access to stored data, credential, internal systems, ...			
Hardware tampering: Modify/implant malicious components in to intercept data, bypass security, or disrupt operations			
Power disruption: Interrupt or manipulate power supply impacting availability and business continuity			
Environmental damage: Environmental events that damage infrastructure, causing data loss, downtime, ...			
INFORMATION SECURITY MANAGEMENT (IMS)			
TODD: notes 12			
Information security governance: System by which IS strategy is controlled to ensure that it supports business objectives, manages risk appropriately, and complies with			
legal and other regulatory requirements. (what)			
Information Security Management System (ISMS): Framework used to manage and protect assets through policies, processes and controls (how)			
Enterprise Information Security Policy (EISP): Information security policy that sets the strategic direction and scope for all an organization's security efforts			
Risk Management Process: Definition of processes to identify assets, analyze threats and evaluate risk			
Security Awareness and Training: Educational programs to ensure employees understand their security responsibilities			
Monitoring, Measurement and Audits: Ongoing evaluation of control effectiveness and ISMS performance			
POLICY			
Practices: Ex. actions that illustrate compliance with policies			
Policy: Instructions that dictate certain behavior within an org			
Standard: Details of what must be done to comply with policy			
Guidelines: Non-mandatory recommendations (reference)			
Procedures: Step-by-step instructions designed to assist employees in following policies			
De jure standard: Formally evaluated and approved by a formal standards organization			
De facto standard: Widely adopted/accepted by public group			
TODD: notes 14,15			
RISK ANALYSIS			
Identify Assets → Identify Threats → Identify Vulnerabilities → Assess Likelihood → Assess Impact → Determine Risk Level			
Asset: Item of value belonging to an organization. eg:			
Information: Customer data, intellectual property, code			
Technical: Services, applications, databases, networks			
Physical: Servers, devices, facilities, infrastructure			
Human: Employees, administrators, contractors			
Business Process: Critical operational workflows			
Threat: An event or action with the potential to cause harm by exploiting a vulnerability. eg: power outage, vishing			
CLASSIFYING ASSETS			
Public: Information that can be shared without risk			
Internal: Information for organization internal use only			
Confidential: Sensitive info, could cause harm if disclosed			
Restricted: Highly sensitive, strictly limited, strongly protected			
SECURITY CONTROLS			
Administrative/Management Controls: Policies, procedures, security training, security governance			
Technical / Logical Controls: Firewalls, encryption, access control systems, system hardening			
Physical Controls: Physical locks, surveillance cameras, secure access badges, turnstiles			
Preventive Controls: Stop incidents before they occur. eg. Firewalls, access control, encryption			
Detective Controls: Identify incidents when they occur. eg. Intrusion detection, log monitoring, SIEM, CCTV			
Corrective Controls: Limit damage, restore systems after an incident. eg. Backups, system restore, incident response			
Deterrent Controls: Discourage malicious behavior. eg. Warning banners, monitoring notices, disciplinary policies			
Compensating Controls: Reduce risk when a primary control cannot be implemented. eg. Network isolation, layered security, alternative safeguards			
Business continuity: Ensures critical operations continue during disruptions. Objectives: maintain operations, minimize impact, protect assets, recover fast			
SECURITY AND AWARENESS TRAINING			
1) Awareness: basic information, what 2) Training: detailed knowledge, how 3) Education: depth of knowledge, why			
GAP ANALYSIS			
Define target framework → Assess curr state → Identify gaps, assess risk → Eval, prioritize gaps → Create remediation plan			
SECURITY FRAMEWORK			
NIST Cybersecurity Framework: Framework for managing cyber risk: Identify, Protect, Detect, Respond, Recover			
CIS Controls: Defines 18 practical technical security controls			
THREATS			
Attack: Act that intends to damage, steal or degrade assets			
Vulnerability: A weakness in a system that can be abused			
Exploit: A method used to take advantage of a vulnerability			
Risk: The likelihood of a threat exploiting a vulnerability and the potential harm that could cause = Vulnerability + Threat			
Threat vector: Path, method, or delivery mechanism that a threat uses to reach an asset and exploit a vulnerability			
Attack surface: Sum of threat vectors that hackers can use to carry out a cyberattack.			
RISK MANAGEMENT (RM)			
The process of identifying, assessing, prioritizing and mitigating threats to an asset from an organisation.			
Risk management process: Implementation, analysis, evaluation of the risk management framework (doing).			
Risk assessment: The identification, analysis, and evaluation of risk as initial parts of risk management.			
Risk treatment & Risk Owner: The application of safeguards or controls to reduce the risks to an organization's information assets to an acceptable level.			
1) Risk identification: Where and what is the risk? 2) Risk analysis: How severe is the current level of risk? 3) Risk evaluation: Is the current level of risk acceptable?			
4) Risk treatment: What do I need to do to bring the risk to an acceptable level?			
Risk management framework: Structure of the strategic planning and design of risk management efforts (planning).			
1) Executive Governance & Support: Support from management and users. 2) Framework Design: Defining the methods and risk appetite strategy. 3) Framework Implementation: Rollout of the plan (through →RM process). 4) Monitoring & Review: How effective is the entire system? 5) Continuous Improvement: Continuous adaptation to new , or existing threats.			
Risk appetite (strategic): The quantity of risk that organizations are willing to accept, to achieve their goals			
Risk tolerance (specific): The acceptable risk organizations are willing to accept for a specific asset			
Residual risk: Remaining risk after controls were applied			
TODD: slides 17,19 (notes 19,20), risk identification, risk analysis			
Common Vulnerabilities and Exposures (CVE): Standard identification number for vulnerabilities			
Common Vulnerability Scoring System (CVSS): Severity scores for vulnerabilities based on CIA (14d 2b remediated)			
QUANTITATIVE RISK ANALYSIS			
1) Assign Asset Value (AV) 1) Identify the organization's information assets. 2) Classify them. 3) Categorize them into useful groups. 4) Prioritize them by overall importance. 2) Calculate Exposure Factor (EF) – percentage of loss that an organization would experience if a specific asset is violated by a realized risk 3) Calculate single loss expectancy (SLE) – Exact amount of loss if an asset were harmed by a threat – SLE = AV × EF 4) Assess the annualized rate of occurrence (ARO) – Expected occurrence frequency of a threat within a year 5) Derive the annualized loss expectancy (ALE) – possible yearly cost of all instances of a realized threat against an asset – ALE = SLE × ARO 6) Perform cost/benefit analysis of counter-measures			
TODD: ALE with safeguards, risk evaluation, risk treatment, mitigation (notes 22,23)			

INFORMATION SECURITY (IS)
Information: Data that has been processed in a way that gives it meaning and value
Information security: Protection of the integrity, confidentiality and availability of information
Non-repudiation: Prevents parties from denying their actions
Accountability: Ability to trace actions back to a person
Authentication: Verifies the identity of a user or system
Authorization: Determines actions an entity is allowed to do
Access control: Restrict access to resources based on rules
Security policy: A rule/expectation for protecting information
Compliance: Adherence to laws, regulations, and standards
Types of information: Personal, business, financial, intellectual, system
Components of an Information System (IS): Software, Hardware, Data, People, Procedures, Networks
Bottom-Up: Implementations happen before policies
Top-Down: Initiated by management, more effective
McCumber cube: x: CIA (what), y: Information states (where), z: Control (how)
(C)onfidentiality: Prevent unauthorized access to info
(I)ntegrity: Protect reliability and correctness of information
(A)vailability: Ensure uninterrupted access to information
Information states: In storage, in transit, in use
Control: A measure designed to reduce the potential risk of an attack by eg. Policy, Education, Technology
(S)poofing: Pretending to be someone else
(T)ampering: Unauthorized data modification or altering
(R)epudiation: Denying actions without proof
(I)nformation disclosure: Exposing sensitive information
(D)enial of service: Making systems or services unavailable
(E)levation of privilege: Gaining unauthorized rights
THREAT CATEGORIZATION
SOCIAL ENGINEERING
Manipulating people to reveal confidential information
Phishing: Forged emails impersonating legitimate entities
Spear Phishing: Targeted phishing to specific individuals
Vishing: Voice-based phishing over phone or video calls
Smishing: SMS / Text-based phishing
SOFTWARE ATTACKS
Exploiting vulnerabilities in software to gain access to a system or steal data
Virus: Malware that attaches to programs and spreads
Worms: Self-replicating malware that spreads over a network
Trojan Horse: Malicious sw disguised as legitimate apps
Ransomware: Encrypts victim data, asks payment to restore
Rootkits: Stealthy tools that hide malicious activity and maintain privileged access
DENIAL OF SERVICE
Overloading one or multiple systems to make it unavailable
DoS: Single source denial of service attacks
DDoS: DoS performed by multiple attackers/devices
Botnet: Network of compromised devices controlled by an attacker and used to together to flood a target with traffic
SYN-Flood Attack: Sending many TCP connection requests without completing them
Reflection Attack: Attacker spoofs victim's IP, sends requests to a service so that it sends (many) replies to victim
WEB APPLICATION ATTACKS
Exploiting vulnerabilities in websites/servers hosting websites
SQL Injection: Insert malicious SQL commands into an input
Cross-Site Scripting (XSS): Inject malicious scripts into website that execute in users' browsers to steal data
Cross-Site Request Forgery (CSRF): Trick logged-in user's browser into sending reqs to a webapp on attacker's behalf
Broken Authentication: Weak auth mechanisms allow attackers to gain unauthorized access (password/session)
PASSWORD / AUTHENTICATION ATTACKS
Attempting to bypass or compromise login systems to gain unauthorized access
Rainbow Table Attacks: Precomputed hash lookup tables to reverse weakly hashed passwords back into plaintext
Password Spraying: Trying a few common passwords like "password" across many accounts to avoid lock-/timeouts
Credential Stuffing: Using leaked credentials from previous breaches to attempt logins on other services
Brute Force Attack: Repeatedly try many username & password combinations until they gain access to an account
PHYSICAL ATTACKS
Bypassing technical controls by accessing physical infrastructure directly
Theft of devices: Physically steal hardware to gain direct access to stored data, credential, internal systems, ...
Hardware tampering: Modify/implant malicious components in to intercept data, bypass security, or disrupt operations
Power disruption: Interrupt or manipulate power supply impacting availability and business continuity

Environmental damage: Environmental events that damage infrastructure, causing data loss, downtime, ...

INFORMATION SECURITY MANAGEMENT (ISMS)

TODO:

notes 12

Information security governance: System by which IS strategy is controlled to ensure that it supports business objectives, manages risk appropriately, and complies with legal and other regulatory requirements. (**what**)

Information Security Management System (ISMS): Framework used to manage and protect assets through policies, processes and controls (**how**)

Enterprise Information Security Policy (EISP): Information security policy that sets the strategic direction and scope for all an organization's security efforts

Risk Management Process: Definition of processes to identify assets, analyze threats and evaluate risk

Security Awareness and Training: Educational programs to ensure employees understand their security responsibilities

Monitoring, Measurement and Audits: Ongoing evaluation of control effectiveness and ISMS performance

POLICY

Practices: Ex. actions that illustrate compliance with policies

Policy: Instructions that dictate certain behavior within an org

Standard: Details of what must be done to comply with policy

Guidelines: Non-mandatory recommendations (reference)

Procedures: Step-by-step instructions designed to assist employees in following policies

De jure standard: Formally evaluated and approved by a formal standards organization

De facto standard: Widely adopted/accepted by public group

TODO:

notes 14,15

RISK ANALYSIS

Identify Assets → Identify Threats → Identify Vulnerabilities → Assess Likelihood → Assess Impact → Determine Risk Level

Asset: Item of value belonging to an organization. eg:

Information: Customer data, intellectual property, code

Technical: Services, applications, databases, networks

Physical: Servers, devices, facilities, infrastructure

Human: Employees, administrators, contractors

Business Process: Critical operational workflows

Threat: An event or action with the potential to cause harm by exploiting a vulnerability. eg: power outage, vishing

CLASSIFYING ASSETS

Public: Information that can be shared without risk

Internal: Information for organization internal use only

Confidential: Sensitive info, could cause harm if disclosed

Restricted: Highly sensitive, strictly limited, strongly protected

SECURITY CONTROLS

Administrative/Management Controls: Policies, procedures, security training, security governance

Technical / Logical Controls: Firewalls, encryption, access control systems, system hardening

Physical Controls: Physical locks, surveillance cameras, secure access badges, turnstiles

Preventive Controls: Stop incidents before they occur. eg. Firewalls, access control, encryption

Detective Controls: Identify incidents when they occur. eg. Intrusion detection, log monitoring, SIEM, CCTV

Corrective Controls: Limit damage, restore systems after an incident. eg. Backups, system restore, incident response

Deterrent Controls: Discourage malicious behavior. eg. Warning banners, monitoring notices, disciplinary policies

Compensating Controls: Reduce risk when a primary control cannot be implemented. eg. Network isolation, layered security, alternative safeguards

Business continuity: Ensures critical operations continue during disruptions. Objectives: maintain operations, minimize impact, protect assets, recover fast

SECURITY AND AWARENESS TRAINING

1) **Awareness:** basic information, **what**

2) **Training:** detailed knowledge, **how**

3) **Education:** depth of knowledge, **why**

GAP ANALYSIS

Define target framework → Assess curr state → Identify gaps, assess risk → Eval, prioritize gaps → Create remediation plan

SECURITY FRAMEWORK

NIST Cybersecurity Framework: Framework for managing cyber risk: Identify, Protect, Detect, Respond, Recover

CIS Controls: Defines 18 practical technical security controls

THREATS

Attack: Act that intends to damage, steal or degrade assets

Vulnerability: A weakness in a system that can be abused

Exploit: A method used to take advantage of a vulnerability

Risk: The likelihood of a threat exploiting a vulnerability and the potential harm that could cause = Vulnerability + Threat

Threat vector: Path, method, or delivery mechanism that a threat uses to reach an asset and exploit a vulnerability

Attack surface: Sum of threat vectors that hackers can use to carry out a cyberattack.

RISK MANAGEMENT (RM)

The process of identifying, assessing, prioritizing and mitigating threats to an asset from an organisation.

Risk management process: Implementation, analysis, evaluation of the risk management framework (doing).

Risk assessment: The identification, analysis, and evaluation of risk as initial parts of risk management.

Risk treatment & Risk Owner: The application of safeguards or controls to reduce the risks to an organization's information assets to an acceptable level.

- 1) **Risk identification:** Where and what is the risk?
- 2) **Risk analysis:** How severe is the current level of risk?
- 3) **Risk evaluation:** Is the current level of risk acceptable?
- 4) **Risk treatment:** What do I need to do to bring the risk to an acceptable level?

Risk management framework: Structure of the strategic planning and design of risk management efforts (planning).

- 1) *Executive Governance & Support:* Support from management and users.
- 2) *Framework Design:* Defining the methods and risk appetite strategy.
- 3) *Framework Implementation:* Rollout of the plan (through →RM process).
- 4) *Monitoring & Review:* How effective is the entire system?
- 5) *Continuous Improvement:* Continuous adaption to new , or existing threats.

Risk appetite (strategic): The quantity of risk that organizations are willing to accept, to achieve their goals

Risk tolerance (specific): The acceptable risk organizations are willing to accept for a specific asset

Residual risk: Remaining risk after controls were applied

TODO:

slides 17,19 (notes 19,20), risk identification, risk analysis

Common Vulnerabilities and Exposures (CVE): Standard identification number for vulnerabilities

Common Vulnerability Scoring System (CVSS): Severity scores for vulnerabilities based on CIA (14d 2b remediated)

QUANTITATIVE RISK ANALYSIS

- 1) Assign Asset Value (AV)
 - 1) Identify the organization's information assets.
 - 2) Classify them.
 - 3) Categorize them into useful groups.
 - 4) Prioritize them by overall importance.
- 2) Calculate Exposure Factor (EF)
 - percentage of loss that an organization would experience if a specific asset is violated by a realized risk
- 3) Calculate single loss expectancy (SLE)
 - Exact amount of loss if an asset were harmed by a threat
 - $SLE = AV \times EF$
- 4) Assess the annualized rate of occurrence (ARO)
 - Expected occurrence frequency of a threat within a year
- 5) Derive the annualized loss expectancy (ALE)
 - possible yearly cost of all instances of a realized threat against an asset
 - $ALE = SLE \times ARO$
- 6) Perform cost/benefit analysis of countermeasures

TODO:

ALE with safeguards, risk evaluation, risk treatment, mitigation (notes 22,23)